

CLICKJACKING

INTRODUCTION

Clickjacking is a serious web vulnerability that targets users by tricking them into clicking on something different from what they perceive. It manipulates the user interface by embedding legitimate web pages within transparent or hidden frames, allowing attackers to hijack clicks and perform unauthorized actions. This attack compromises both security and user trust, and is often used in combination with social engineering. Understanding how to detect and exploit clickjacking is crucial for every web application pentester.

1. What is Clickjacking?

Clickjacking (also known as UI redressing) is a web-based attack where a malicious actor tricks a user into clicking on something different from what they intended. It typically involves embedding a legitimate website in an invisible iframe overlaid on a fake interface. When the user clicks, they're unknowingly performing actions like:

- Changing account settings
- Submitting sensitive information
- Liking a page or sharing content
- Confirming transactions

Clickjacking doesn't exploit technical vulnerabilities in the code — it exploits trust and poor frame restrictions.

2. Tools Used to Detect Clickjacking

Here are some commonly used tools to detect clickjacking vulnerabilities:

1. Clickjacking Test Page

- o PortSwigger and other websites offer test pages to check if a URL is vulnerable by rendering it inside an iframe.

2. Burp Suite Professional / Community Edition

- o Can be used to intercept and test HTTP responses to check if X-Frame-Options or Content-Security-Policy headers are present.

3. SecurityHeaders.com

- o Online scanner that checks headers like X-Frame-Options.

4. OWASP ZAP (Zed Attack Proxy)

- o Can scan websites and identify missing frame-busting headers.

3. Three Ways to Exploit Clickjacking Vulnerability

Here are three common techniques attackers use to exploit clickjacking vulnerabilities:

1. Hidden Iframe with Fake Button

- The attacker loads the target site in an invisible iframe
- Places a fake "Play" or "Submit" button over the real action
- Victim clicks, unknowingly performing a legitimate action (e.g., transferring money)

2. Likejacking (Social Engineering)

- Used to gain followers or likes on social media
- An attacker frames the "Like" button invisibly
- Victims think they're clicking a game or image, but end up liking a page

3. Clickjacking Login or Settings Change

- The attacker embeds the user settings page of a legitimate site
- Traps the user into clicking on "Delete Account" or "Change Email" buttons

CONCLUSION

Clickjacking may appear simple, but its impact can be severe when combined with user trust and poor frame protections. Through this task, I gained practical knowledge of how clickjacking works, explored tools to detect it, and learned different methods used to exploit this vulnerability. Completing the

PortSwigger labs reinforced how critical browser security headers are in defending against such threats. This task strengthened my understanding of both user-centric attacks and client-side web security.

COMPLETED LABS

Clickjacking

LAB	APPRENTICE Basic clickjacking with CSRF token protection →	✓ Solved
LAB	APPRENTICE Clickjacking with form input data prefilled from a URL parameter →	✓ Solved
LAB	APPRENTICE Clickjacking with a frame buster script →	✓ Solved
LAB	PRACTITIONER Exploiting clickjacking vulnerability to trigger DOM-based XSS →	✓ Solved
LAB	PRACTITIONER Multistep clickjacking →	✓ Solved